Security Group and NACL Challenge

Step-by-step build guide (VPC / Security Groups / NACL / EC2)

Prepared by: **Sukhada Wagale** | Date: **16 October 2026**

1. What you will build

A custom VPC with public subnets, two security groups (**SGA** and **SGB**) and two EC2 web servers. You test connectivity with HTTP, SSH (EC2 Instance Connect), ping (ICMP) and curl, then tighten the rules step by step and use a Network ACL (NACL) to block your home IP.

Concept	Security Group	Network ACL
Level	Instance (network interface)	Subnet
State	**Stateful** - reply traffic is allowed automatically	**Stateless** - need rules for both directions
Rules	Allow rules only	Allow **and** Deny rules
Evaluation	All rules evaluated together	Lowest rule number first; first match wins

Before you start

- Region: use any one Region (e.g. **us-east-1**) for the whole project and do not switch.
- Find your home public IPv4 address at `https://checkip.amazonaws.com` (needed in Part 7).
- Estimated cost is very low (2 x t3.micro for under an hour). Delete everything at the end (Part 10).

2. Part 1 - Create the custom VPC

1. Open the **VPC** console > **Your VPCs** > **Create VPC**.
2. Select **VPC and more** (not 'VPC only').
3. Name tag auto-generation: keep it ticked and enter **lab1-custom**. The VPC will be named lab1-custom-vpc.
4. IPv4 CIDR block: keep **10.0.0.0/16**. IPv6: **No IPv6 CIDR block**.
5. Number of Availability Zones: **2**. Public subnets: **2**. Private subnets: **2**.
6. **NAT gateways: None** (important, NAT costs money). VPC endpoints: keep default (S3 Gateway) or None.
7. DNS options: keep both **Enable DNS hostnames** and **Enable DNS resolution** ticked.
8. Click **Create VPC** and wait for the workflow to finish, then click **View VPC**.

Enable auto-assign public IPv4 on the public subnets

1. VPC console > **Subnets**. Filter by VPC **lab1-custom-vpc**.
2. Select **lab1-custom-subnet-public1-us-east-1a** > **Actions** > **Edit subnet settings**.
3. Tick **Enable auto-assign public IPv4 address** > **Save**.
4. Repeat for **lab1-custom-subnet-public2-us-east-1b**.

> **Why:** public subnets have a route to the Internet Gateway, but an instance also needs a public IPv4 address to be reachable. Auto-assign gives every new instance in that subnet one.

3. Part 2 - Create security groups SGA and SGB

Create **SGA first**, because SGB has a rule that references SGA.

3.1 Create SGA

1. VPC console > **Security groups** > **Create security group**.
2. Security group name: **SGA**. Description: *Security group A*. VPC: **lab1-custom-vpc** (do not leave the default VPC!).
3. Add the rules below, keep the default outbound rule, then click **Create security group**.

Direction	Type	Protocol / Port	Source	Description
Inbound	HTTP	TCP 80	0.0.0.0/0	HTTP from anywhere
Inbound	SSH	TCP 22	0.0.0.0/0	SSH from anywhere
Outbound	All traffic	All	0.0.0.0/0	All outbound (default rule)

3.2 Create SGB

1. **Create security group** again. Name: **SGB**. Description: *Security group B*. VPC: **lab1-custom-vpc**.
2. Add the inbound rules below. For the ICMP rule choose Source type **Custom** and select **SGA** from the list (it shows as sg-xxxx).
3. Keep the default outbound rule (all traffic) and click **Create security group**.

Direction	Type	Protocol / Port	Source	Description
Inbound	HTTP	TCP 80	0.0.0.0/0	HTTP from anywhere

Direction	Type	Protocol / Port	Source	Description
Inbound	SSH	TCP 22	0.0.0.0/0	SSH from anywhere
Inbound	All ICMP - IPv4	ICMP / N/A	SGA	ICMP from SGA
Outbound	All traffic	All	0.0.0.0/0	All outbound (default rule)

4. Part 3 - Launch the two EC2 instances

4.1 Instance A (in SGA)

1. **EC2** console > **Instances** > **Launch instances**.
2. Name: **instance-A**. AMI: **Amazon Linux 2023** (free tier eligible). Instance type: **t3.micro** (or t2.micro).
3. Key pair: choose **Proceed without a key pair** (we connect with EC2 Instance Connect).
4. Network settings > click **Edit**: VPC = **lab1-custom-vpc**, Subnet = **lab1-custom-subnet-public1-us-east-1a**, Auto-assign public IP = **Enable**.
5. Firewall: **Select existing security group** > choose **SGA**.
6. Expand **Advanced details**, scroll to **User data** and paste the script below.
7. Click **Launch instance**.

```
#!/bin/bash
yum update -y
yum install -y httpd
systemctl start httpd
systemctl enable httpd
```

4.2 Instance B (in SGB)

1. Repeat the same steps. Name: **instance-B**. Subnet: public1 (same subnet) or **public2-us-east-1b** (both are accepted by the lab).
2. Select existing security group **SGB**. Use the same user data script.
3. When both instances are **Running** with **2/2 checks passed**, note down: public IPv4 and private IPv4 of **each** instance.

> **Tip:** wait about 2 minutes after launch so the user data script finishes installing Apache before you test the web page.

5. Part 4 - Initial connectivity tests (all should work)

#	Test	How	Expected
1	Web page, instance A	Browser: `http://<public IP of A>` (use http, not https)	Apache test page
2	Web page, instance B	Browser: `http://<public IP of B>`	Apache test page
3	SSH to A and B	EC2 > select instance > **Connect** > **EC2 Instance Connect** tab > **Connect**	Terminal opens
4	Ping B from A	On A: `ping -c 4 <private IP of B>`	Replies received
5	Curl A from B	On B: `curl http://<public IP of A>`	HTML of the test page

The Apache page may read 'It works!' or 'Test Page for the Apache HTTP Server' depending on the AMI. Both mean Apache is running.

Why these work

- **Browser / curl:** both SGs allow inbound TCP 80 from 0.0.0.0/0 and the public subnet routes to the Internet Gateway.
- **EC2 Instance Connect:** uses SSH (port 22), allowed from 0.0.0.0/0.
- **Ping A to B:** SGB allows inbound ICMP from SGA; SGA outbound is open and replies are allowed automatically (stateful).
- **Ping B to A will NOT work yet** because SGA has no ICMP rule. You fix this in Part 7.

6. Part 5 - Make the changes and test again

Change 1: SGA allows HTTP only from your home IP

1. EC2 > **Security Groups** > **SGA** > **Inbound rules** > **Edit inbound rules**.
2. On the HTTP rule change the Source from 0.0.0.0/0 to **My IP** (it fills your address as x.x.x.x/32). Leave SSH unchanged. Save.

Test:

- Browser at home to A's public IP: **works**.
- On B: `curl --max-time 10 http://<public IP of A>`: now **times out** (B's public IP is not your home IP). This is the expected result.
- EC2 Instance Connect to A: still works (SSH rule unchanged).

Change 2: Use a NACL to deny your home IP

1. VPC console > **Network ACLs**. Select the NACL associated with your public subnets (the default one for lab1-custom-vpc; check the **Subnet associations** tab).
2. **Inbound rules** > **Edit inbound rules** > **Add new rule**.
3. Rule number: **50** (must be lower than the existing allow-all rule 100). Type: **All traffic**. Source: **your home IP/32**. Allow/Deny: **Deny**. Save.

Test:

- Browser at home to A's public IP (and B's, if in the same subnet): now **times out**, even if the SG allows you.
- Browser from another network (e.g. mobile data) to B's public IP still works as long as SGB allows HTTP from anywhere.
- EC2 Instance Connect still works, because its traffic comes from AWS IP ranges and not your home IP.

Why the NACL wins: a NACL is checked at the subnet boundary **before** the security group. A Deny at rule 50 matches first and the packet is dropped. **Remove rule 50 afterwards** (select it > Delete) so the next tests are not affected by your home IP block.

Change 3: SGB allows HTTP only from SGA

1. EC2 > **Security Groups** > **SGB** > **Edit inbound rules**.
2. On the HTTP rule change Source from 0.0.0.0/0 to **Custom** and select **SGA**. Save.

Test:

- Browser to B's public IP: now **times out**.
- On A: `curl http://<private IP of B>`: **works**. Use the **private** IP; a rule that references a security group matches the private address of the sender/target.

Change 4: Enable ICMP in both directions

1. **SGA** > Inbound rules > **Add rule**: Type **All ICMP - IPv4**, Source **Custom = SGB**. Save.
2. **SGB** already has inbound ICMP from SGA. Outbound on both groups is 'All traffic', so ICMP can already leave in both directions. If you want it explicit, add an outbound **All ICMP - IPv4** rule on SGA (destination SGB) and on SGB (destination SGA).
3. Confirm the NACL still has the default allow-all rules for inbound and outbound (rule 100) and that your rule 50 deny has been removed.

Test:

```
# On instance A
ping -c 4 <private IP of B>

# On instance B
ping -c 4 <private IP of A>
```

7. Part 6 - Final test matrix

Test	Expected result	Reason
Home browser to A (HTTP)	Works (after NACL deny removed)	SGA allows HTTP from My IP
Home browser to A (with NACL deny)	Fails / times out	NACL rule 50 denies home IP
Other network browser to A	Fails	SGA allows HTTP only from home IP
Browser to B public IP	Fails	SGB allows HTTP only from SGA
A curl B private IP	Works	SGB allows HTTP from SGA
B curl A public IP	Fails	B's public IP is not your home IP
A ping B private IP	Works	ICMP allowed from SGA
B ping A private IP	Works	ICMP allowed from SGB (Change 4)
EC2 Instance Connect to A and B	Works	SSH 22 open to 0.0.0.0/0

8. Troubleshooting

Problem	Check
Web page does not load at all	Using http:// not https://; instance has a public IP; SG has inbound 80; wait 2 min for user data; subnet route table has 0.0.0.0/0 to igw.
No public IP on instance	Auto-assign enabled on subnet or on the launch screen. Existing instances need an Elastic IP.
EC2 Instance Connect fails	SG allows inbound 22; instance is in a public subnet with a public IP; NACL not blocking.
Ping fails	Inbound ICMP rule exists with the correct SG as source; ping the **private** IP; NACL allows ICMP both ways.
Rules not applying	SGs and the NACL belong to **lab1-custom-vpc**, not the default VPC.
Locked out after NACL deny	Your own IP is blocked. Delete rule 50 from another network or from the console (the console is not affected).

9. Key takeaways

- Security groups are stateful, allow-only and attached to instances; NACLs are stateless, have allow and deny rules and are attached to subnets.
- A security group can use another security group as source, which is more flexible and safer than IP ranges.
- NACL rules are evaluated by rule number; lower number wins. Put deny rules below 100 to override the default allow-all.
- Public subnet = route to an Internet Gateway; a public IP is also required for internet reachability.

10. Clean up

1. EC2 > Instances: select instance-A and instance-B > **Instance state** > **Terminate**.
2. VPC > Network ACLs: make sure the deny rule 50 is removed (or the VPC delete will remove it anyway).
3. VPC > Security groups: delete **SGB** first, then **SGA** (SGB references SGA).
4. VPC > Your VPCs: select **lab1-custom-vpc** > **Actions** > **Delete VPC**. This also deletes the subnets, route tables and internet gateway.